记一次渗透测试#信息收集之测试环境

目　录

1、　为什么会有这篇文章 3

2、　漏洞挖掘之验证码突破..... 6

1、为什么会有这篇文章

由于最近发现挺多真实业务的测试环境为 qqqtest.xxx.com、testxxx.yyy.com 等格式

就有了两个思路

◆遍历可访问子域名的测试环境

◆遍历可能存在测试环境的子域名

第一种：首先获取一份子域名列表，然后替换主域名为 test.主域名格式（.baidu.com ---> test.baidu.com。即 qwe.baidu.com --> qwetest.baidu.com），再检测是否可以访问。

部分代码如下：（测试版本）

```
def main():
    headers={'User-Agent':'Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:68.0) Gecko/20100101 Firefox/68.0'}

    o = open('BaiDu-subdomain.txt')  #引入已获取得子域名，使用时需修改
    sd = [line.strip() for line in o.readlines()]
    o.close
    url = []
    for i in sd:
        domain = i.replace(".baidu.com", "test.baidu.com")  #替换主域名为测试主域名，使用时需修改
        test_url = 'http://'+domain+''
        url.append(test_url)

    q = Queue.Queue(5)          #加线程
    for my_url,s in zip(url,range(89999)):
        q.put(s)
        t = Threads(my_url,headers,q)
        t.start()
    q.join()
```

效果如下：

```
def main():
    headers={'User-Agent':'Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:68.0) Gecko

    o = open('BaiDu-subdomain.txt')  #引入已获取得子域名，使用时需修改
    sd = [line.strip() for line in o.readlines()]
    o.close
    url = []
    for i in sd:
        domain = i.replace(".baidu.com", "test.baidu.com")  #替换主域名为测试主域名，
        test_url = 'http://'+domain+''
        url.append(test_url)

    q = Queue.Queue(5)          #加线程
    for my_url,s in zip(url,range(89999)):
        q.put(s)
        t = Threads(my_url,headers,q)
        t.start()
    q.join()


if __name__ == '__main__':
        main()
```

```
p://[redacted]t.baidu.com            不存在
p://[redacted]est.baidu.com          不存在
p://[redacted]est.baidu.com          不存在
p://[redacted]test.baidu.com         不存在
p://[redacted]onetest.baidu.com          不存在
p://[redacted]test.baidu.com         不存在
p://[redacted]orks.baijiatest.baidu.com          不存在
p://[redacted]atest.baidu.com        status:200
p://[redacted]est.baidu.com          不存在
```

第二种：站在前辈的肩膀上，修改相关子域名字典，直接跑脚本。

修改 lijiejie 的 subDomainsBrute 工具，这里遍历的是：xxxtest、testxxx、ceshixxx 格式。

效果如下：

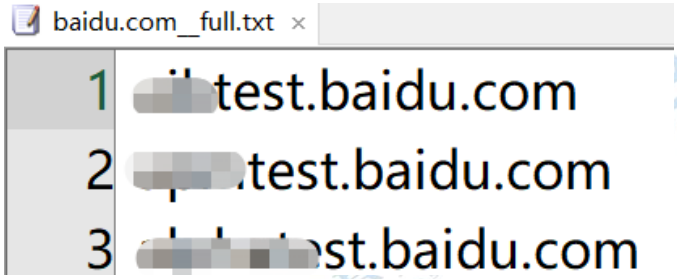
```
D:[redacted]subDomainsBrute-master-v1.4 - cs
λ python subDomainsBrute.py baidu.com --full
SubDomainsBrute v1.4  https://github.com/lijiejie/subDomainsBrute
[+] Validate DNS servers
[+] Server 119.29.29.29     < OK >   Found 4
[+] 4 DNS Servers found
[+] Run wildcard test
[+] Start 6 scan process
[+] Please wait while scanning ...

[|] 13 found, 334949 scanned in 1054.7 seconds, 30179 groups left
```

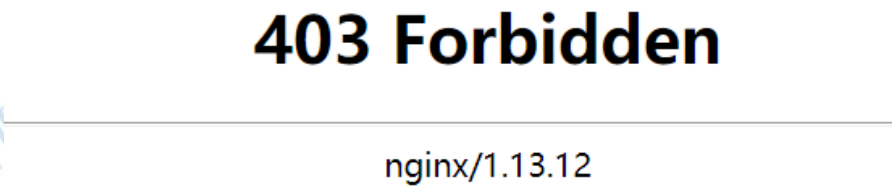
test.b u.co n
test.ba u.c
test d.ba u n
test.bai u.c n
test.ba u m
tes .b id o n
tes b id n
tes b du co n
test .ba d co n 180.1
test.b u.co n
test.ba u.co n
test.ba u.co
test.b du.c m

2、漏洞挖掘之验证码突破

开始测试收集到的测试地址



其中有个地址打开是 403 页面



平常可能会碰到很多站点打开是 404 403 页面...

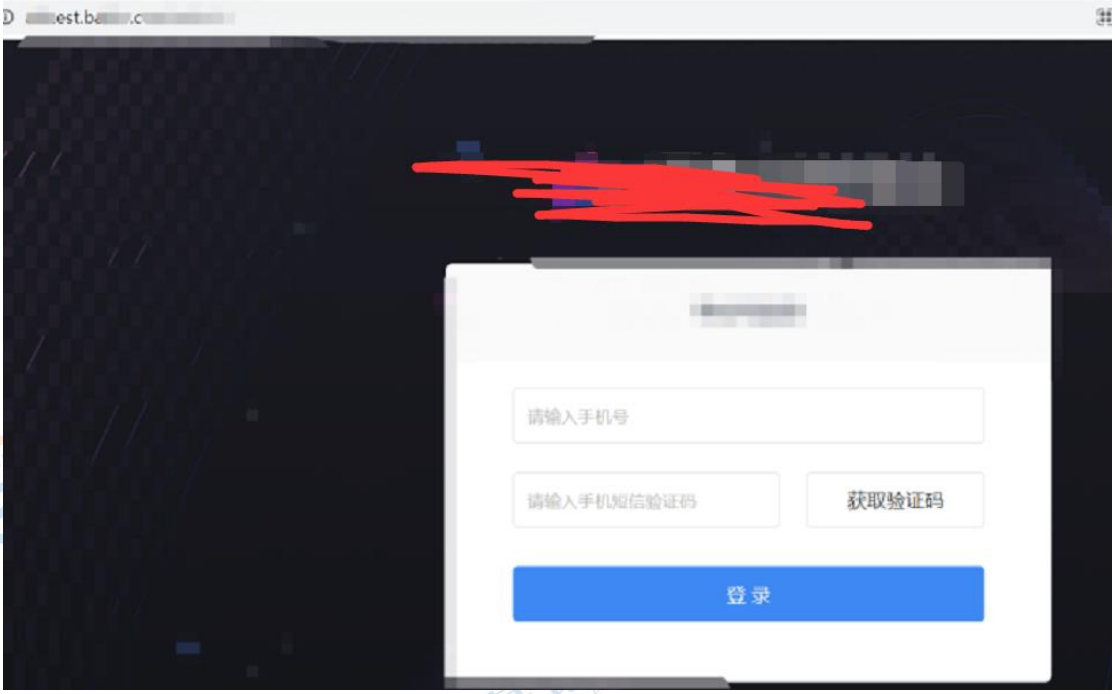
但是不要慌，dirsearch 来帮忙

看到这一排的 200

```
[17:26:14] 200 -    5KB - /admin_album.asp
[17:26:14] 200 -    5KB - /admin_album.aspx
[17:26:14] 200 -    5KB - /admin_album.do
[17:26:14] 200 -    5KB - /admin_album.action
[17:26:14] 200 -    5KB - /admin_album.cgi
[17:26:14] 200 -    5KB - /admin_album.pl
[17:26:14] 200 -    5KB - /admin_album.html
[17:26:14] 200 -    5KB - /admin_album.htm
[17:26:14] 200 -    5KB - /admin_album.json
[17:26:14] 200 -    5KB - /admin_album.tar.gz
[17:26:14] 200 -    5KB - /admin_album.tgz
[17:26:14] 200 -    5KB - /admin_alldel.php
[17:26:14] 200 -    5KB - /admin_alldel.jsp
[17:26:14] 200 -    5KB - /admin_alldel.jsf
[17:26:14] 200 -    5KB - /admin_alldel.aspx
[17:26:14] 200 -    5KB - /admin_alldel.asp
[17:26:14] 200 -    5KB - /admin_alldel.do
[17:26:14] 200 -    5KB - /admin_alldel.action
[17:26:14] 200 -    5KB - /admin_alldel.cgi
[17:26:14] 200 -    5KB - /admin_alldel.pl
[17:26:14] 200 -    5KB - /admin_alldel.html
[17:26:14] 200 -    5KB - /admin_alldel.htm
[17:26:14] 200 -    5KB - /admin_alldel.json
[17:26:14] 200 -    5KB - /admin_alldel.tar.gz
[17:26:14] 200 -    5KB - /admin_alldel.tgz
[17:26:14] 200 -    5KB - /admin_area.php
[17:26:14] 200 -    5KB - /admin_area
```

直接访问/admin

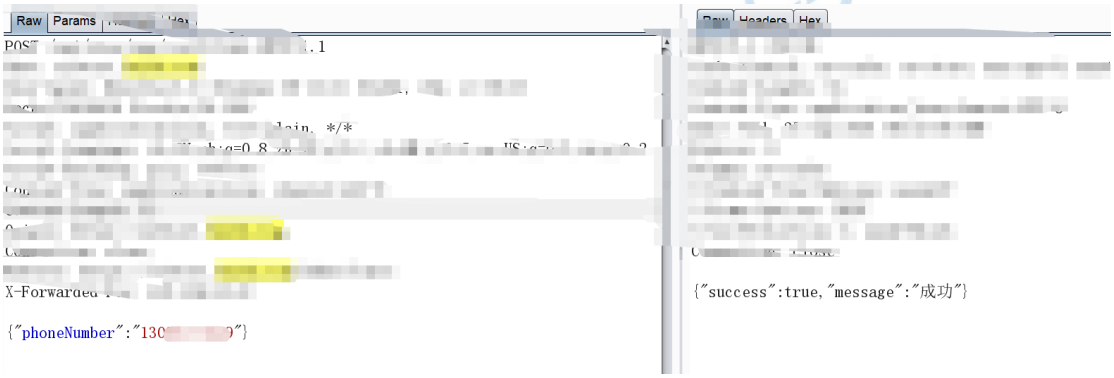
然后就发现了一个登录页面



看到发送验证码，首先想的是来一波短信轰炸。

简单操作：首先获取发送验证码的请求包，然后一直重放，看是否收到次数大概一致的短信数量。

这里有限制，虽然一直重放，回显都是成功，但是一分钟内好像只能收到三条短信。未再深入思考....



从本机收到的验证码来看，这里使用的使用的验证码位数为 4 位，且没有说明几分钟内有效，可能存在可以爆破验证码达到绕过验证码验证的环节。

设置需要爆破的参数值

"verifyCode":"§1234§","phoneNumber":"130[redacted]3"

然后导入字典

be customized in different ways.

Payload set: 1 Payload count: 8,766

Payload type: Numbers Request count: 8,766

Payload Options [Numbers]

This payload type generates numeric payloads within a given range and in a specified

Number range

Type: Sequential Random

From: 1234

To: 9999

Step: 1

How many:

开始爆破

得到验证码为 5472。（由于我未在此系统内注册，所以返回用户名不存在，且没有相关的权限）

5742	403			467
	500			472
1234	500			472
1236	500			472
1235	500			472
1238	500			472
1239	500			472
1237	500			472
1244	500			472
1241	500			472
1243	500			472
1240	500			472

Response

aders Hex

ed, 25 Aug 2021 08:33:54 GMT

: 0

no-cache

nt-Type-Options: nosniff

-Options: DENY

rotection: 1; mode=block

ion: close

s":"com.bai[redacted]on","msg":"验证码错误","code":1000}

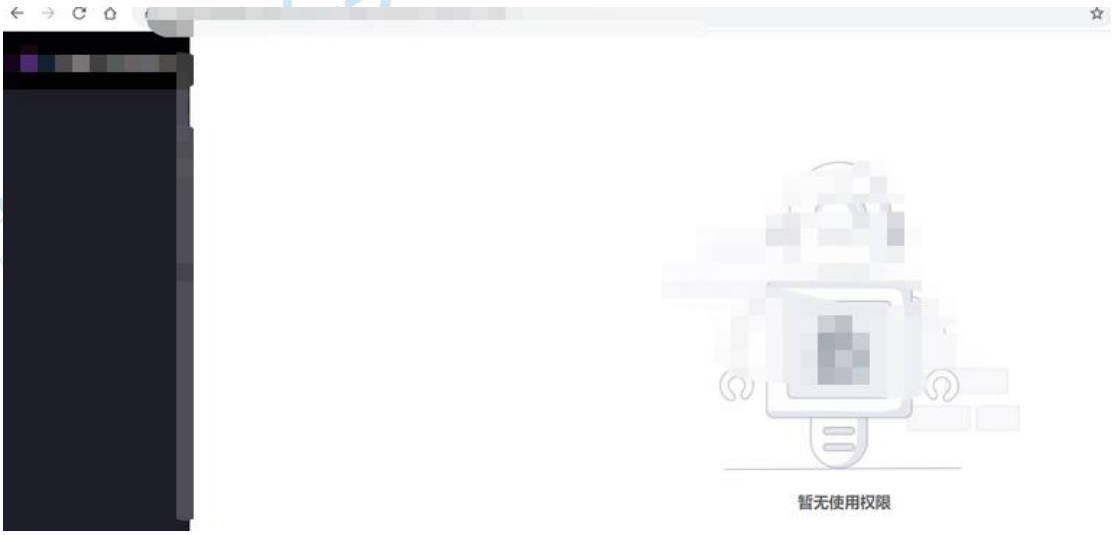
Payload	Status	Error	Timeout	Length	Comment
5742	403			467	
	500			472	
1234	500			472	
1236	[illegible]			472	
1235	[illegible]			[illegible]	
1238	500			472	
1239	500			472	
1237	500			472	
1244	[illegible]			472	
1241	500			472	
1243	500			472	
1240	500			472	

st Response

Headers Hex

```
Wed, 25 Aug 2021 08:34:50 GMT
s: 0
: no-cache
ent-Type-Options: nosniff
e-Options: DENY
Protection: 1; mode=block
tion: close

[illegible]on","msg":"用户不存在！","code":1
```



如果已知一个存在的用户（手机号），是可以通过这种方式进入系统内的。

....